WerbSMSI

Piloter la sécurité de l'information du groupe et de ses sites industriels

Comité de validation de la démarche de mise en œuvre et de gestion

Novembre 2026 · Version 0.28 de l'environnement, 16 modules publiés

Ce que nous demandons au comité

Quatre décisions, dans l'ordre où elles conditionnent la suite

1 Valider la démarche

Un SMSI piloté au niveau du groupe, décliné par site, construit en sept étapes et douze mois, avec WerbSMSI comme outil unique.

2 Nommer les acteurs

Un sponsor à la direction, un référent cyber (RSSI) pour le groupe, un correspondant par site. Les temps réalistes sont chiffrés en page 10.

3 Retenir le site pilote

Un site industriel représentatif pour les phases 0 à 2 (deux mois), avant l'extension aux autres sites.

4 Approuver les règles de gestion

Espace sur le drive protégé, un dossier par site, droits documentés, sauvegarde de l'espace, journal versionné, revues trimestrielles et annuelle.

Pourquoi s'en occuper maintenant

Trois constats qui se renforcent

Des obligations qui se précisent

- NIS2 : gestion des risques, notification des incidents, responsabilité de la direction.
- IEC 62443 : exigences cyber des projets industriels.
- CRA : suivi du cycle de vie des produits numériques dès décembre 2027.
- RGPD : registre des traitements, violations.

Une réalité de terrain dispersée

- Les registres d'exploitation vivent dans des classeurs Excel, sans vue d'ensemble.
- Inventaires, schémas, prestataires et sauvegardes ne sont pas reliés entre eux.
- Les preuves demandées par un audit ou un assureur se reconstruisent à chaque fois.

Une contrainte propre à l'industriel

- Les réseaux OT sont cloisonnés : pas de cloud, pas de serveur applicatif à maintenir.
- Les outils doivent fonctionner hors ligne, sur un poste isolé, sans rien installer.
- Les données décrivent l'outil de production : elles restent sur le drive de l'entreprise.

WerbSMSI en un coup d'œil

Un environnement modulaire, hors ligne, sur fichiers

16

modules publiés

chacun autonome, avec son dépôt et ses tests

6

rubriques

de la gouvernance à la résilience

2

niveaux

le groupe pilote, chaque site gère

0

serveur, 0 cloud

des pages HTML et des fichiers JSON sur le drive

Comment cela fonctionne

Chaque module est une page HTML qui s'ouvre dans Edge et travaille sur une base JSON rangée dans l'espace du groupe ou du site. Un portail commun donne la vue d'ensemble : sites, conformité, risques, socle de mesures, bases à jour.

Les modules ne se parlent que par des fichiers de publication, écrits sur action explicite : WerbMap publie les actifs, WerbExploitation les sauvegardes et le cycle de vie des logiciels, WerbEBIOS les risques… et chacun lit ce dont il a besoin.

Six rubriques, seize modules

Groupe : pilotage et références communes · Site : actifs, analyses, exigences, exploitation

Gouvernance SMSI

groupe

- WerbGouvernance — politique (assistant PSSI), rôles, socle de mesures, procédures, revues, plan d'actions
- WerbReferentiels — ANSSI, NIST, NIS2, ISO 27001, CRA, RGPD en lecture

Analyse des risques

groupe et site

- WerbEBIOS — EBIOS Risk Manager : analyse d'entreprise au groupe, déclinée par site, rapport Word

Inventaires ICS

site

- WerbMap — VLAN, adressage, actifs, flux, systèmes d'information
- WerbAssets — configuration des équipements réseau
- WerbCartoSI — registre des schémas d'architecture

Conformité et exigences

groupe et site

- WerbNIS2 — audit NIS2, plan d'actions, preuves
- WerbIEC62443 — exigences des projets industriels
- WerbPresta — prestataires, cahier d'exigences, évaluation
- WerbRGPD — traitements, violations, demandes

Exploitation MCO / MCS

site (catalogue au groupe)

- WerbExploitation — registres, matériel et logiciels (PLM), inventaires de machines
- WerbRecette — recette réseau et non-régression
- WerbPentest — test d'intrusion autorisé et remédiation

Continuité et résilience

site · formation au groupe

- WerbPCR — plan de continuité et de reprise (RTO, RPO)
- WerbVeille — veille menaces, CVE de vos logiciels (NVD)
- WerbAcademie — formations, sensibilisation, indicateurs

Le groupe pilote, les sites gèrent

Ce qui descend, ce qui remonte, ce qui reste sur place

🏢 Groupe

- Politique de sécurité (PSSI) et charte utilisateur
- Rôles et responsabilités
- Échelles de cotation et événements redoutés
- Socle de mesures exigé sur tous les sites
- Modèle d'exigences envers les prestataires
- Catalogue matériel et logiciel, listes de choix
- Formations et indicateurs

diffuse

échelles, événements redoutés, socle de mesures, exigences, listes de choix, catalogue

remonte

des synthèses seulement : niveaux de risque, taux de conformité, indicateurs de formation — jamais le détail des sites

📍 Chaque site

- Inventaire : réseaux, actifs, flux, systèmes
- Analyse de risques déclinée du groupe
- Audits NIS2, IEC 62443, RGPD du site
- Registres d'exploitation, sauvegardes, PLM
- Prestataires, schémas, tests, veille
- Plan de continuité et de reprise

Les règles de sécurité de l'environnement

Fixées par la charte commune, contrôlées par un audit automatique à chaque publication

Hors ligne par construction

La politique de sécurité de chaque page bloque toute connexion sortante. Rien n'est installé, rien ne part vers Internet.

Les données restent sur le drive

Bases JSON dans l'espace SMSI_<GROUPE>, un dossier par site : la protection est celle des droits du dossier, décrits dans DROITS.md.

Rien dans le navigateur

Pas de cache, pas de stockage local : à la fermeture, le poste ne garde aucune donnée.

Des échanges explicites

Un module publie sur action « Publier » un fichier par module ; les autres le lisent sans le modifier. Un seul propriétaire par objet.

Intégrité et traçabilité

Chaque enregistrement crée une version avec commentaire et empreinte chaînée ; le journal des modifications est conservé dans la base ; verrou « ouvert par… ».

Aucun secret dans les outils

Ni mot de passe ni clé : le coffre-fort reste à part. Les secrets du kit de veille restent sur la machine de collecte.

La démarche : un parcours en sept étapes

L'ordre du portail, repris dans le guide « Démarrer avec WerbSMSI »

1	2	3	4	5	6	7
Gouverner	**Connaître son SI**	**Comprendre les risques**	**Maîtriser les exigences**	**Contrôler le terrain**	**Assurer la résilience**	**Faire vivre le SMSI**
WerbGouvernance, WerbReferentiels	WerbMap, WerbAssets, WerbCartoSI	WerbEBIOS	WerbNIS2, WerbIEC62443, WerbPresta, WerbRGPD	WerbExploitation, WerbRecette, WerbPentest	WerbPCR, WerbVeille	WerbAcademie, portail, revues

Planifier → Faire → Vérifier → Améliorer : les étapes 1 à 4 préparent, la 5 agit et contrôle, la 6 prépare l'incident, la 7 boucle chaque année.

La feuille de route sur douze mois

Site pilote : phases 0 à 2 en deux mois, puis extension ; durées pour un référent à temps partiel

0	1	2	3	4	5
semaines 1 – 2	mois 1 – 2	mois 2 – 4	mois 3 – 6	mois 4 – 9	mois 9 – 12, puis annuel
Décider et s'organiser	**Savoir ce qu'on a**	**Comprendre ses risques**	**Fixer les règles et le plan**	**Agir et vérifier**	**Piloter et améliorer**
Nommer, fixer le périmètre, créer l'espace et les droits, déclarer les rôles, former la direction.	Inventaire, sauvegardes, comptes, prestataires, schémas. Gains rapides : sauvegarde hors ligne testée, mots de passe par défaut, accès distants.	EBIOS au groupe (échelles, événements redoutés) puis par site ; premier état des lieux NIS2.	PSSI, socle de mesures, plan d'actions, cahiers d'exigences prestataires, plan de formation, plan de continuité.	Mesures en place, registres tenus, prestataires évalués, recette réseau, test d'intrusion, veille active.	Revue de direction, plan de reprise testé, audit NIS2 avec preuves, risques mis à jour.

Qui fait quoi, et combien de temps

Les temps sont réalistes, pas théoriques : ils figurent dans le guide remis à chaque acteur

Rôle	Mission	Temps réaliste
Dirigeant (sponsor)	Décide, donne les moyens, arbitre les risques, se forme, préside la revue annuelle	½ journée par trimestre, plus les arbitrages
Référent cyber / RSSI	Pilote la démarche, tient WerbSMSI à jour, anime ateliers et sensibilisations	de 20 % d'un temps plein (un site) à un temps plein (plusieurs sites)
Correspondant de site	Fait vivre la démarche sur son site : inventaire, registres, prestataires, plan d'actions local	1 à 2 jours par mois
Responsable OT / maintenance	Connaît les automates, la supervision, les fenêtres d'arrêt, les intervenants	ateliers ponctuels, inventaire initial
Informatique	Comptes, sauvegardes, mises à jour, réseau, coffre-fort de mots de passe	intégré au quotidien
RH / managers	Recensent les personnes à former, libèrent du temps pour les sessions	quelques heures par trimestre
Achats	Intègrent le cahier d'exigences cyber aux contrats des prestataires	à chaque contrat
Prestataires	Tests d'intrusion, audits, intégration ; répondent au questionnaire d'exigences	selon les besoins

La gestion au quotidien : le rythme de croisière

Ce que la démarche demande une fois en place

Chaque semaine	Trier les alertes de veille ; vérifier que les sauvegardes ont tourné	WerbVeille, WerbExploitation
Chaque mois	Mises à jour, comptes, certificats ; avancement du plan d'actions ; nouveaux arrivants à former	WerbExploitation, WerbGouvernance, WerbAcademie
Chaque trimestre	Comité cyber avec la direction (30 minutes : risques, actions, incidents, formation) ; sessions de formation ; indicateurs publiés	Portail, WerbGouvernance, WerbAcademie
À chaque changement	Recette réseau, mise à jour de l'inventaire ; nouveau prestataire : cahier d'exigences avant le premier accès	WerbRecette, WerbMap, WerbPresta
Chaque année	Revue de direction, mise à jour EBIOS, évaluation des prestataires, test de restauration, test d'intrusion, exercice de reprise, audit NIS2	WerbGouvernance, WerbEBIOS, WerbPresta, WerbPCR, WerbPentest, WerbNIS2
Tous les deux ans	Renouvellement des formations ; suppression des personnes parties au-delà de la durée de conservation	WerbAcademie

Ce que la démarche prouve

Chaque référentiel trouve son outil et ses livrables

Référentiel	Dans WerbSMSI	Livrables et preuves
NIS2	WerbNIS2 (20 règles, 152 points) ; preuves tirées de WerbAcademie, WerbCartoSI, WerbExploitation	Audit, couverture, plan d'actions, rapport
IEC 62443	WerbIEC62443 au groupe et par site ; exigences envers les intégrateurs et prestataires (WerbPresta)	Exigences cadre, cahier d'exigences, niveaux de maturité
ISO 27001 / ANSSI	WerbGouvernance : PSSI selon le guide ANSSI, rôles, socle de mesures, revues ; WerbReferentiels	Politique approuvée, charte utilisateur, revue de direction
EBIOS Risk Manager	WerbEBIOS : cinq ateliers, MITRE ATT&CK, risques consolidés au groupe	Analyse de risques, décisions de traitement, rapport Word
RGPD	WerbRGPD : registre des traitements, violations (72 h), demandes d'exercice des droits	Registre, journal des violations, critères d'AIPD
CRA et cycle de vie	WerbExploitation : références matériel et logiciel, fin de support, CPE ; WerbVeille : CVE du NVD	État PLM par site, alertes de vulnérabilités
Continuité (ISO 22301)	WerbPCR : plan de continuité (PCI) et de reprise (PRI), RTO et RPO par système	Plans par site, exercices de reprise

Les risques de la démarche, et ce qui les contient

Dits avant qu'on ne nous les oppose

La démarche s'essouffle après le lancement

Un comité cyber trimestriel de trente minutes, des tableaux de bord qui signalent les retards, un rythme de croisière écrit et peu coûteux. Le sponsor préside la revue annuelle.

Un outil porté par une seule personne

Code source lisible, charte écrite, un dépôt par module, 153 suites de tests automatisés, guides pour chaque module : la reprise est possible sans son auteur.

Des données sensibles sur le parc

Elles restent sur le drive de l'entreprise, un dossier par site, droits documentés, sauvegarde de l'espace avec manifeste d'empreintes. Aucun secret n'est stocké.

Ce qui sort vers l'extérieur

Uniquement le kit de veille, sur une machine connectée séparée : sources publiques ; la recherche de CVE au NVD est désactivée par défaut et n'envoie que les noms de logiciels, jamais les TAG ni le site.

Où en est l'environnement aujourd'hui

Prêt pour un site pilote

16 / 16

modules publiés

audit de la charte sans erreur

153

suites de tests

exécutées dans Edge, sur un espace de démonstration

47

guides d'accompagnement

lisibles dans chaque module et dans le portail

2

sites de démonstration

groupe fictif, sites LYON et NANTES, données inventées

✅ Ce qui est en place

- Portail : vue groupe et site, mise en place guidée, sauvegarde et restauration
- Rapports Word et PDF au modèle de l'entreprise
- Feuille de route tenue à chaque livraison

🧭 Ce qui reste prévu

- Registre des vulnérabilités du site alimenté par la veille (WerbExploitation)
- Gestion des changements des systèmes industriels (MOC)
- Publication des alertes de veille vers les fiches SI de WerbMap

Décisions et prochaines étapes

Si le comité valide, la phase 0 commence la semaine prochaine

À décider aujourd'hui

1. La démarche en sept étapes et douze mois
2. Le sponsor, le référent cyber, le correspondant du site pilote
3. Le site pilote
4. Les règles de gestion : espace, droits, sauvegarde, revues

Les deux premières semaines

- Annonce de la direction et nomination des acteurs
- Création de l'espace du groupe et du site pilote dans le portail ; droits appliqués sur le drive ; sauvegarde programmée
- Rôles déclarés dans WerbGouvernance ; académie créée
- Session « Cybersécurité : le rôle des dirigeants » pour l'équipe de direction
- Point d'étape au comité à deux mois : inventaire du site pilote et premiers gains rapides